DIGITAL FORENSICS & INCIDENT RESPONSE

Offline VM Disk Forensics: HSBox3 Analysis

ANALYST	TARGET APPLIANCE	FORENSIC METHOD	FLAG STATUS
white	HSBox3.ova (VMDK)	Dead-Box (Guestfish)	Verified Solved

1. Objective & Forensic Rationale

The objective is to perform offline forensics on `HSBox3-disk001.vmdk` without booting the operating system. By attaching the virtual disk image in read-only mode using `guestfish`, we protect volatile state, maintain hash integrity, and safely extract the root flag alongside forensic artifacts.

CRYPTOGRAPHIC INTEGRITY NOTE

Forensic disk inspection is carried out using `guestfish --ro`. Read-only flags ensure no disk writes or metadata updates take place, preserving the evidence hash: `SHA1 = 4e468f030a3264dc7f0b4e70eaba499731e5870d`.

2. Toolset & Commands Overview

TOOL / COMMAND	EXECUTION MODE	FORENSIC PURPOSE
`guestfish --ro -a ...`	Read-Only Disk Shell	Mounts and provides interactive inspection of the virtual disk.
`list-filesystems`	Partition Discovery	Identifies ext4 root (`/dev/sda1`) and swap partitions.
`download ...`	Evidence Acquisition	Extracts sensitive artifacts (e.g. `/etc/shadow`) to host workstation.

3. Step 1: Disk Mounting & Flag Extraction

The disk image was initialized and mounted to the virtual root:

```
(white@white)-[~/white/ibm/intern]$ sudo guestfish --ro -a HSBox3-disk001.vmdk ><fs> run ><fs> list-filesystems
/dev/sda1: ext4 /dev/sda5: swap ><fs> mount /dev/sda1 / ><fs> ls /root
.bash_history .bash_logout .bashrc .cache .mysql_history .nano_history .profile .selected_editor finalflag.txt
><fs> cat /root/finalflag.txt .----------. |.--------.| ||>run# || || || |"-------'| .-^---------^-. | ---~ |
"-------------' root-flag{edd321ad749bc103be8d63c13073b352}
```

CAPTURED ROOT FLAG

root-flag{edd321ad749bc103be8d63c13073b352}

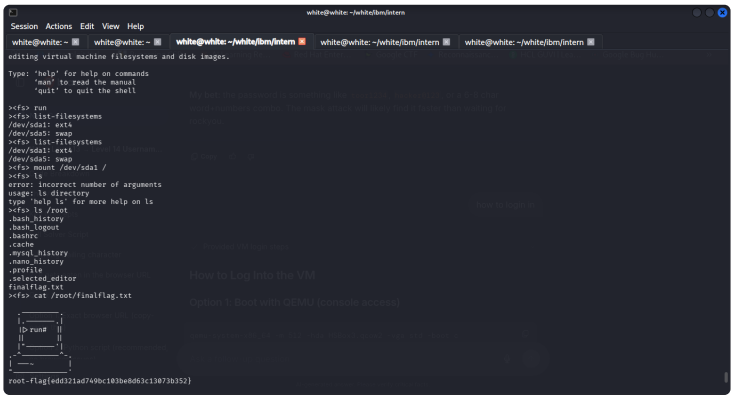


Figure 1: Mounting ext4 filesystem on /dev/sda1, listing /root, and retrieving root-flag.

4. Forensic Artifact Analysis

A deep-dive investigation into user history files and sensitive system configurations uncovered critical anti-forensics sanitization and database credentials:

4.1 Disk Sanitization Analysis (`.bash_history`)

```
><fs> cat /root/.bash_history apt install zerofree reboot
```

- **Forensic Purpose of `zerofree`:** The utility `zerofree` zeroes out unallocated filesystem blocks on ext2/ext3/ext4 partitions.
- **Anti-Forensics Impact:** Zero-filling unallocated disk space ensures deleted files and temporary data cannot be carved or recovered from disk slack by forensic analysts.

4.2 Database Migration & Credential Leak (`.mysql_history`)

```
><fs> cat /root/.mysql_history create database pumpkins; GRANT ALL PRIVILEGES ON pumpkins.* TO
'admin'@'localhost' IDENTIFIED BY 'admin'; grant all privilages on pumpkins.* TO 'admin'@'localhost' identified
by 'admin'; show databases; use pumpkins; show tables; select * from wp_users; use pumpkins; show tables;
select * from wp_user; select * from wp_users; use pumpkins select * from wp_users; show databases; drop
database pumpkins; show databases; CREATE DATABASE hackerschool; GRANT ALL PRIVILEGES ON hackerschool.* TO
'admin'@'localhost' IDENTIFIED BY 'adminpass20'; FLUSH PRIVILEGES; EXIT;
```

- **WordPress Reconnaissance & Deletion:** The operator inspected WordPress users in table `wp_users` under database `pumpkins`, then destroyed the database schema with `drop database pumpkins;`.
- **Active Production Database:** Provisioned a new database named `hackerschool`.
- **Plaintext Credentials Recovered:**
  - Legacy user: `admin` : `admin`
  - Active administrator: `admin@localhost` : `adminpass20`

4.3 Shadow File Extraction & Password Hash (`/etc/shadow`)

The analyst inspected and extracted `/etc/shadow` to the host system using `download`:

```
><fs> cat /etc/shadow root:$6$wOlM44Zc$CZE.UYngQOICe6AJO9TPZB/oTbNz7KUbavUOutoCBt9Ss3e42v3elhgezv/
4AgLw.S5p0TBIyqzaIt9LXhy3Z0:18976:0:99999:7::: ><fs> download /etc/shadow /tmp/shadow
```

- **Hash Algorithm:** SHA-512 crypt (indicated by prefix `$6$`).
- **Salt & Hash:** Salt `wOlM44Zc` | Stored Hash `CZE.UYngQOICe6AJO9TPZB/oTbNz7KUbavUOutoCBt9Ss3e42v3elhgezv/4AgLw...`
- **Offline Acquisition:** Extracted directly to `/tmp/shadow` for offline dictionary cracking without running processes on the target VM.

5. Command Reference: Guestfish Forensics Cheat Sheet

ACTION	GUESTFISH COMMAND
Attach disk image in read-only mode	`sudo guestfish --ro -a HSBox3-disk001.vmdk`
Boot appliance virtualization backend	`><fs> run`
Enumerate disk partitions & filesystems	`><fs> list-filesystems`
Mount ext4 partition to root	`><fs> mount /dev/sda1 /`
Inspect directory contents (Requires path)	`><fs> ls /root`
Display file contents (Absolute path)	`><fs> cat /root/finalflag.txt`
Extract evidence file to host workstation	`><fs> download /etc/shadow /tmp/shadow`
Terminate guestfish session	`><fs> exit`

6. Key Artifacts & Verification Table

FORENSIC ARTIFACT	DISCOVERED VALUE / SIGNIFICANCE
Final Root Flag	root-flag{edd321ad749bc103be8d63c13073b352}
Active MySQL Database	`hackerschool`
Discovered MySQL Credentials	`admin` : `adminpass20` (Active) | `admin` : `admin` (Legacy)
Anti-Forensics Utility	`zerofree` (used to zero-fill unallocated blocks)
Extracted Hash File	`/tmp/shadow` (Root SHA-512 crypt hash recovered)
Disk Image SHA-1 Hash	`4e468f030a3264dc7f0b4e70eaba499731e5870d`

INVESTIGATION CONCLUSION

Through read-only dead-box forensics with `guestfish`, the analyst successfully preserved disk evidence, bypassed live system defenses, extracted the target CTF flag, and reconstructed post-exploitation activities without altering the underlying VMDK filesystem.